

must be authenticated. There is a simple embedded hardware approach to keeping these kinds of trusted systems secure. An authentication scheme was instituted many years ago for medical and consumer products such as printer cartridges. These systems traditionally employ a standards based authentication process, using a custom secure device.

This authentication scheme is based on the challenge-response exchange between the host and the slave device (Fig. 4). The host system sends a challenge used by the slave system to compute a response. This response is validated by the host system to make sure the slave system is not cloned or counterfeited. Only after validation does the host communicate with the slave system.

A simple conceptual block diagram of a hardware based authentication scheme similar to the symmetric SHA-256 algorithm is shown in Fig. 5. The SHA-256 protocol, based on a challenge-response exchange between authorized devices, authenticates the sensor before its data is accepted and read. SHA-256 authentication makes it almost impossible for an attacker to connect to a network, to pretend to be a sensor or to replace the sensor system with a compromised system, un-

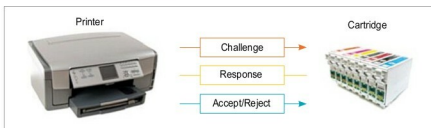


Fig. 4: Authenticating the slave module—can be used with both a field sensor and an I/O module

less the hacker has an identical authentication device with the same programmed-in private key.

Vendors provide the key programming service at an American facility and then ship a programmed authentication device to you. This device has a unique key that is known only to you. Devices that store the key are tamper-proof with a range of active and passive tamper protections built-in.

Risks with PLCs, CPUs and solutions

What controls your plant or process is the PLC and the main CPU that is running all control algorithms. But these systems are never designed to withstand security attacks and breaches. Hence, once these systems are connected online, there are many ways to compromise the main CPU of the PLC. Some of the attack surfaces can be applications software, operating systems or hardware, but the most vulnerable surface is firmware. If the firmware

can be modified or infected, any change due to malware is not only hard to detect but also, if found, is very difficult to ascertain the intention or purpose behind it.

Most PLCs lack source and data authentication on firmware uploads. Some PLCs even lack checksums for validating the correct transfer of the firmware. If the attacker can modify the PLC firmware, he or she can:

- Take complete control over the infected system
- Learn about the production process
- Selectively sabotage the manufacturing operation (aka Stuxnet)
- Propagate to the enterprise from a trusted manufacturing system

Not everyone wants to take control of your system to destroy your plant. The risks can be more subtle. There is a lot of intellectual property embedded in a manufacturing setup, and sometimes the intent is merely to get this intellectual property. This kind of malware will not manifest itself by creating problems in your manufacturing setup.

Automation World once reported, "The interesting thing about Dragonfly is that it targeted ICS information not for the purpose of causing downtime, but for the purpose of intellectual property theft. Potential damage could include the theft of proprietary recipes and production batch sequence steps, as well as network and device information that indicate manufacturing plant volumes and capabilities."

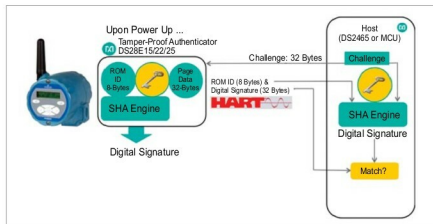


Fig. 5: Sensor authentication with SHA-256 (private key)